

GS+ + control deltas github 20.04.26 & 29.05.26

Inhalte

- [Entfernte Anforderungen](#)
- [Neue Anforderungen](#)
- [Veränderte Anforderungsattribute](#)

Zu jeder entfernten Anforderungen wird die neue Anforderung mit der höchsten [Kosinus-Aehnlichkeit](#) (cos-sim) genannt, wenn diese ≥ 0.5 ist. Unberücksichtigt bleiben bei der cos-sim-Berechnung Interpunktion, einige [Stoppwoerter](#), Wortreihenfolge sowie Groß- und Kleinschreibung.

Entfernte Anforderungen

[Zurück zu Inhalte](#)

Anzahl entfernter Anforderungen: 7

- DET.3.1.13 Integration von Cloud-Diensten (erhöht)

Detektion für Cloud-Dienste KANN Ereignisse in der Cloud im Audit Log der Institution protokollieren.

- GEB.5.4 Schutz gegen Manipulation (erhöht)

Gebäudemanagement für IT-Systeme KANN Manipulationsschutzvorkehrungen installieren.

- GEB.5.5 Physische Mikrosegmentierung (erhöht)

Gebäudemanagement für IT-Systeme KANN eine physische Mikrosegmentierung installieren.

- GEB.10.2.8 Brandschutzprüfung (normal-SdT)

Gebäudemanagement für Standorte SOLLTE die Wirksamkeit der Brandschutzmaßnahmen {regelmäßig} überprüfen.

- KONF.2.5.1.1 Automatische Konfigurationsverwaltung (normal-SdT)

Konfiguration für Endgeräte SOLLTE die Verwaltung durch ein Mobile Device Management (MDM) verankern.

- SENS.8.4.1 Beaufsichtigung Externer (normal-SdT)

Sensibilisierung für Mitarbeitende von Standorten SOLLTE zur Beaufsichtigung von Externen in sensiblen Bereichen anweisen.

- TEST.4.1.1.1 Staging (normal-SdT)

Änderungen und Tests SOLLTE die freizugebenden Änderungen in einer von der Produktumgebung getrennten Staging-Umgebung, deren Komponenten so weit wie möglich der Produktivumgebung entsprechen, testen.

Neue Anforderungen

[Zurück zu Inhalte](#)

Anzahl neuer Anforderungen: 7

+ **DET.3.6 Unbestreitbarkeit (erhöht)**

Detektion für Daten KANN Nachweise für den Zusammenhang {bestimmter Ereignisse} mit {einer bestimmten Person oder Rolle} dokumentieren.

+ **KONF.2.9 Abgesicherter und authentisierter Bootprozess (erhöht)**

Konfiguration für IT-Systeme KANN einen abgesicherten und authentisierten Bootprozess aktivieren.

+ **SENS.8.9 Rückgabe nicht mehr benötigter Assets (normal-SdT)**

Sensibilisierung für Nutzende SOLLTE zur Rückgabe nicht mehr benötigter Assets anweisen.

+ **SENS.8.10 Vermeidung von Brandlasten (normal-SdT)**

Sensibilisierung für Nutzende von Standorten SOLLTE das ungesicherte Hinterlassen von Brandlasten untersagen.

+ **SENS.8.11 Verwendung von Brandschuttmitteln (normal-SdT)**

Sensibilisierung für Mitarbeitende SOLLTE zur korrekten Verwendung bereitgestellter Brandschutz-Hilfsmittel sensibilisieren.

+ **SENS.8.12 Verwendung von Wasserschuttmitteln (erhöht)**

Sensibilisierung für Mitarbeitende KANN zur korrekten Verwendung bereitgestellter Wasserschutz-Hilfsmittel sensibilisieren.

+ **TEST.4.1.3 Dokumentation der Freigabe (normal-SdT)**

Änderungen und Tests SOLLTE die Freigabe einschließlich Zeitpunkt, Vorhaben, Freigabekriterien und freigebender Personen dokumentieren.

Veraenderte Anforderungsattribute

[Zurück zu Inhalt](#)

Anzahl geänderter Anforderungsattribute: 277

Anforderung	Geänderte Attribute
ARCH.2.3	Tags
ARCH.4.1.1	Tags
ARCH.4.1.2	Tags

Anforderung	Geänderte Attribute
ASST.2.2	Tags
ASST.5.6	Verwandte
ASST.5.7	Verwandte
ASST.6.1	Verwandte
BER.1.4	Tags
BER.3.4	Tags
BER.3.5	Tags
BER.3.11	Tags
BER.3.12	Tags
BER.5.1.1	Tags
BER.5.1.2	Tags
BER.6.4	Ergebnis, Hinweis, Text
BES.1.4	Modalverb, Text
DET.2.1	Hinweis
DET.3.1	Verbesserung
DET.3.2	Dokumentation, Ergebnis, Handlungswort, Hinweis, Parameter, Präzisierung, Text, Titel, UUID, Zielobjekte
DET.3.3	Aufwand, Ergebnis, Handlungswort, Hinweis, Modalverb, Parameter, Präzisierung, Sicherheitsniveau, Text, Titel, UUID, Verwandte
DET.3.4	Ergebnis, Handlungswort, Hinweis, Parameter, Präzisierung, Tags, Text, Titel, UUID
DET.3.5	Aufwand, Ergebnis, Hinweis, Modalverb, Parameter, Präzisierung, Sicherheitsniveau, Text, Titel, UUID, Zielobjekte
DET.4.5	Aufwand, Sicherheitsniveau
DET.4.8	Ergebnis, Hinweis, Text, Verwandte
DET.4.10	Tags
DET.4.11.1	Tags
DET.4.11.2	Tags
DET.5.3	Aufwand
DET.5.8.1.1	Aufwand
DEV.2.6	Aufwand
DEV.2.6.2	Aufwand

Anforderung	Geänderte Attribute
DEV.7.2	Hinweis, Verwandte
GEB.5.1	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Präzisierung, Text, Titel, UUID, Zielobjekte
GEB.5.2	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Modalverb, Präzisierung, Sicherheitsniveau, Text, Titel, UUID, Zielobjekte
GEB.5.3	Aufwand, Ergebnis, Hinweis, Modalverb, Präzisierung, Sicherheitsniveau, Text, Titel, UUID, Zielobjekte
GEB.7.2	Text, Zielobjekte
GEB.10.2	Verbesserung, Verwandte
GEB.10.2.5	Dokumentation, Ergebnis, Handlungswort, Hinweis, Text, Titel, UUID
GEB.10.2.6	Aufwand, Ergebnis, Handlungswort, Hinweis, Modalverb, Sicherheitsniveau, Text, Titel, UUID, Zielobjekte
GEB.10.2.7	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Modalverb, Parameter, Präzisierung, Sicherheitsniveau, Tags, Text, Titel, UUID, Zielobjekte
KONF.2.5	Verbesserung
KONF.2.5.1	Verbesserung
KONF.2.6	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Modalverb, Sicherheitsniveau, Tags, Text, Titel, UUID, Zielobjekte
KONF.2.7	Ergebnis, Hinweis, Text, Titel, UUID
KONF.2.8	Dokumentation, Ergebnis, Handlungswort, Hinweis, Tags, Text, Titel, UUID
KONF.6.5	Tags
KONF.11.1	Tags
KONF.11.1.2	Tags
KONF.14.1	Tags
KONF.14.1.2	Tags
REA.2.5	Modalverb, Text
SENS.4.1.5	Aufwand
SENS.4.1.6	Aufwand
SENS.8.1	Aufwand, Ergebnis, Handlungswort, Hinweis, Präzisierung, Text, Titel, UUID, Verwandte, Zielobjekte
SENS.8.2	Aufwand, Ergebnis, Hinweis, Präzisierung, Tags, Text, Titel, UUID, Zielobjekte

Anforderung	Geänderte Attribute
SENS.8.3	Aufwand, Ergebnis, Handlungswort, Hinweis, Modalverb, Sicherheitsniveau, Tags, Text, Titel, UUID, Verwandte, Zielobjekte
SENS.8.4	Aufwand, Ergebnis, Hinweis, Modalverb, Präzisierung, Sicherheitsniveau, Tags, Text, Titel, UUID, Verbesserung, Zielobjekte
SENS.8.5	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Modalverb, Sicherheitsniveau, Tags, Text, Titel, UUID, Zielobjekte
SENS.8.6	Aufwand, Ergebnis, Hinweis, Modalverb, Sicherheitsniveau, Tags, Text, Titel, UUID, Zielobjekte
SENS.8.7	Aufwand, Dokumentation, Ergebnis, Handlungswort, Hinweis, Tags, Text, Titel, UUID, Verwandte, Zielobjekte
SENS.8.8	Aufwand, Ergebnis, Hinweis, Modalverb, Sicherheitsniveau, Tags, Text, Titel, UUID, Zielobjekte
TEST.4.1	Verbesserung
TEST.4.1.1	Verbesserung
TEST.4.1.2	Ergebnis, Handlungswort, Hinweis, Präzisierung, Text, Titel, UUID, Verwandte

ARCH.2.3 Mikrosegmentierung (erhöht)

Attribut	20.04.26	29.05.26
Tags	Zero Trust, Advanced Persistent Threats (APT), Lateral Movement	Advanced Persistent Threats (APT), Lateral Movement

ARCH.4.1.1 Dynamische Netzzugangskontrolle (normal-SdT)

Attribut	20.04.26	29.05.26
Tags	Network Access Control, Rogue Access Point, Zero Trust	Network Access Control, Rogue Access Point

ARCH.4.1.2 Quarantäne (erhöht)

Attribut	20.04.26	29.05.26
Tags	Network Access Control, Rogue Access Point, Zero Trust	Network Access Control, Rogue Access Point

ASST.2.2 Inventar der Systeme (normal-SdT)

Attribut	20.04.26	29.05.26
Tags	Inventories, Zero Trust	Inventories

ASST.5.6 Wartung durch Externe (erhöht)

Attribut	20.04.26	29.05.26
Verwandte	#SENS.8.4	#SENS.8.6

ASST.5.7 Dokumentation von Wartungen (normal-SdT)

Attribut	20.04.26	29.05.26
Verwandte	#TEST.4.1.2	#TEST.4.1.3

ASST.6.1 Abhandenkommen (normal-SdT)

Attribut	20.04.26	29.05.26
Verwandte	#REA.1.1, #SENS.8.1	#REA.1.1, #SENS.8.3

BER.1.4 Inventar der Berechtigungen (normal-SdT)

Attribut	20.04.26	29.05.26
Tags	Zero Trust	

BER.3.4 Identität-Zugangskonto (normal-SdT)

Attribut	20.04.26	29.05.26
Tags	Zero Trust	

BER.3.5 Privilegierte Zugangskonten (normal-SdT)

Attribut	20.04.26	29.05.26
Tags	Zero Trust, Privilege Escalation, Insider Threat, Privilegierte Rechte	Privilege Escalation, Insider Threat, Privilegierte Rechte

BER.3.11 Systemsperre bei Inaktivität (normal-SdT)

Attribut	20.04.26	29.05.26
Tags	Automatic Session Locking, Zero Trust	Automatic Session Locking

BER.3.12 Sperre der Anwendung bei Inaktivität (normal-SdT)

Attribut	20.04.26	29.05.26
Tags	Automatic Session Locking, Zero Trust	Automatic Session Locking

BER.5.1.1 Rollenbasierte Berechtigung (normal-SdT)

Attribut	20.04.26	29.05.26
Tags	Zero Trust	

BER.5.1.2 JIT-/JEA-Berechtigungen (erhöht)

Attribut	20.04.26	29.05.26
Tags	Zero Trust	

BER.6.4 Mehr-Faktor-Authentisierung am Perimeter (normal-SdT)

Attribut	20.04.26	29.05.26
Ergebnis	Mehr-Faktor-Authentisierung	Phishing-resistente Mehr-Faktor-Authentisierung
Hinweis	Aus externen Netzen wie dem Internet [- erreichbaren -] Anwendungen (insbesondere die VPN- Einwahl oder Cloud- Anwendungen) [- stellen -] ein beliebtes Ziel für Angreifer [- dar -]. [- Eine Mehr -] [- Faktor -] [- Authentifizierung erschwert einen unberechtigten Zugang zu diesen extern erreichbaren Anwendungen -].	
	[+ Phishing - resistente Mehr - Faktor - Authentisierung bezeichnet Verfahren zur Anmeldung , bei denen mindestens zwei unterschiedliche Faktoren genutzt werden und bei denen die Authentisierung zusätzlich gegen typische Angriffe wie Credential Phishing , Adversary - in - the - Middle - Angriffe oder die Wiederverwendung abgefangener Sitzungsdaten abgesichert ist . Phishing - resistente Verfahren basieren typischerweise auf kryptographischen Nachweisen zwischen Endgerät und Zielsystem und verhindern dadurch , dass einmal abgefragte Zugangsdaten oder Einmalcodes durch täuschend echte Anmeldeseiten weiterverwendet werden können , beispielsweise FIDO2 Passkeys . Hintergrund ist , dass +] aus externen Netzen wie dem Internet [+ erreichbare +] Anwendungen (insbesondere die VPN- Einwahl oder Cloud- Anwendungen) ein beliebtes Ziel für Angreifer [+ sind +]. [+ Klassische Passwörter oder einfache Einmalcodes könnten durch Social Engineering +], [+ gefälschte Login +] [+ Portale oder Man +] - [+ in - the - Browser - Angriffe ausgespäht werden . +]	
Text	Berechtigung für Anwendungen von Externe Netzanschlüssen SOLLTE Mehr-Faktor-Authentisierung aktivieren.	Berechtigung für Anwendungen von Externe Netzanschlüssen SOLLTE Phishing-resistente Mehr-Faktor-Authentisierung aktivieren.

BES.1.4 Outsourcing-Strategie (erhöht)

Attribut	20.04.26	29.05.26
Modalverb	KANN	SOLLTE
Text	Beschaffungsmanagement für Outsourcing KANN eine Strategie mit Zielen, Chancen und Risiken des Outsourcings verankern.	Beschaffungsmanagement für Outsourcing SOLLTE eine Strategie mit Zielen, Chancen und Risiken des Outsourcings verankern.

DET.2.1 Meldeverfahren (normal-SdT)

Attribut	20.04.26	29.05.26
Hinweis	[- Zweck ist es einerseits Nutzenden das schnelle Melden von potenziellen Sicherheitsproblemen zu ermöglichen -] und [- andererseits -] die zuständigen Stellen [- zu einer schnellen -] Reaktion [- auf Vorfälle anzuhalten -].	[+ Ein Meldeverfahren bezeichnet in diesem Kontext einen nachvollziehbaren +] und [+ definierten Ablauf zur Erfassung , Weiterleitung und Bearbeitung erkannter sicherheitsrelevanter Ereignisse oder Auffälligkeiten („ Incident Reporting “ oder „ Security Event Reporting “) . Dazu gehört , welche Ereignisse als meldepflichtig gelten , über welche Kommunikationswege Meldungen erfolgen können , welche Stellen dabei informiert werden und innerhalb welcher Zeiträume eine Bearbeitung stattfindet . Die Anforderung zielt darauf ab , dass erkannte Sicherheitsereignisse nicht unbeachtet bleiben oder nur informell kommuniziert werden . Ohne ein geregeltes Vorgehen könnte ein Vorfall verspätet bearbeitet werden , wichtige Informationen könnten verloren gehen oder Warnhinweise könnten nicht +] die zuständigen Stellen [+ erreichen . Ein etabliertes Meldeverfahren kann hingegen eine schnelle +] Reaktion, [+ eine konsistente Bewertung von Ereignissen und eine koordinierte Behandlung erkannter Auffälligkeiten unterstützen . Die konkrete Ausgestaltung kann sich dabei an Größe , Struktur und Schutzbedarf der Institution orientieren . Geeignet sind etwa zentrale Meldestellen , Ticketsysteme , standardisierte Meldeformulare und abgestufte Eskalationsprozesse . +]

DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse (normal-SdT)

Attribut	20.04.26	29.05.26
Verbesserung	DET.3.1.1, DET.3.1.2, DET.3.1.3, DET.3.1.4, DET.3.1.5, DET.3.1.6, DET.3.1.7, DET.3.1.8, DET.3.1.9, DET.3.1.10, DET.3.1.11, DET.3.1.12, DET.3.1.13	DET.3.1.1, DET.3.1.2, DET.3.1.3, DET.3.1.4, DET.3.1.5, DET.3.1.6, DET.3.1.7, DET.3.1.8, DET.3.1.9, DET.3.1.10, DET.3.1.11, DET.3.1.12

DET.3.2 Integration von Cloud-Diensten (erhöht)

Attribut	20.04.26	29.05.26
Dokumentation	Detektions-Konzept	Audit Log
Ergebnis	die Protokollierung nicht benötigter Inhalte	Ereignisse in der Cloud
Handlungswort	einschränken	protokollieren
Hinweis	[- Je nach Anwendung und Konfigurationseinstellungen -] könnten [- Protokolle auch -] Daten [- enthalten , die dort nicht benötigt werden -], z. B. [- um die Vertraulichkeit der Daten zu wahren oder aufgrund von Compliance - Anforderungen . Dem kommt eine noch höhere Bedeutung zu , wenn die Protokolle zwischen Institutionen ausgetauscht , oder bei Cloud - Dienstleistern gespeichert oder analysiert werden . Maßnahmen können z . B . Anonymisierung von -] IP- Adressen oder [- anderen personenbezogenen Daten oder Geschäftsgeheimnissen , sowie enge Löschfristen sein . -] Für [- Verkehrsdaten kann der BfDI Leitfaden Speicherung Verkehrsdaten als Grundlage genutzt werden . Soweit möglich , ist -] es [- sinnvoll , die Filterung minimalinvasiv -] zu [- gestalten , d . h . nur diejenigen Daten auszufiltern , deren Speicherung nicht rechtlich oder tatsächlich möglich ist , die restlichen Angaben zum Ergebnis jedoch -] zu [- protokollieren . -]	[+ Daten in Cloud - Diensten +] könnten [+ von Angreifern über das Internet angegriffen werden , ohne dass Ereignisse im internen Netz hierauf Rückschlüsse geben . Dies könnte zum Beispiel durch Phishing geschehen , wodurch ein OAuth Token für den Cloud - Zugang missbraucht wird . Die Integration der Logs des Cloud - Dienstleisters in die institutionseigene Protokollierung kann hier helfen , z . B . bei Authentifizierung oder Berechtigungsänderungen , sowie bei Zugriff oder Veränderung von +] Daten [+ . Insbesondere die Integration des Loggings mit einer bedingten Zugriffsrichtlinie kann hier helfen +], z. B. [+ indem Zugriffe von ungewöhnlichen +] IP- Adressen oder [+ Browser Agents auf Angriffe hinweisen können . Die Integration von Cloud - Protokollen in ein internes Logging birgt oft erhebliche Herausforderungen , darunter die Bewältigung des enormen Volumens und der Vielfalt an Datenformaten , was durch selektive Protokollierung , Datennormalisierung und - anreicherung angesprochen werden kann . Die Absicherung der Datenpipeline gegen Man - in - the - Middle - Angriffe kann durch die Einhaltung der technischen Anforderungen an die beteiligten IT - Systeme und Anwendungen bewältigt werden , z . B . Verschlüsselung und Authentifizierung . Da Cloud - Anbieter oftzusätzliche Gebühren +] für [+ den Datentransfer (Egress - Kosten) verlangen bietet +] es [+ sich an , die Protokolle vor der Übertragung +] zu [+ filtern , um die

Attribut	20.04.26	29.05.26
		Kosten für die Verbesserung der Sicherheit gering +] zu [+ halten . +]
Parameter	{'det.3.2-prm1': 'Kriterien'}	
Präzisierung	anhand von {{Kriterien}}	im Audit Log der Institution
Text	Detektion KANN die Protokollierung nicht benötigter Inhalte anhand von {{insert: param, det.3.2-prm1 }} einschränken.	Detektion für Cloud-Dienste KANN Ereignisse in der Cloud im Audit Log der Institution protokollieren.
Titel	Filterung nicht benötigter Inhalte	Integration von Cloud-Diensten
UUID	fa239d57-3934-4664-bc2d-53aca634eaef	681494bd-8d1d-4b34-84f6-abab2f4ea751
Zielobjekte	Cloud-Dienste	

DET.3.3 Filterung nicht benötigter Inhalte (erhöht)

Attribut	20.04.26	29.05.26
Aufwand	4	5
Ergebnis	den für die Protokollierung zur Verfügung stehenden Speicherplatz	die Protokollierung nicht benötigter Inhalte
Handlungswort	überprüfen	einschränken
Hinweis	[- Diese Vorschrift zielt darauf ab -], die [- Verfügbarkeit -] der [- Protokolldaten sicherzustellen -]. [- Das -] ist [- essenziell , da eine unterbrochene oder lückenhafte Aufzeichnung die Früherkennung von Angriffen unmöglich machen könnte , was dazu führen könnte , dass kritische forensische Beweise für eine Untersuchung fehlen -]. Die [- Umsetzung dieser Anforderung kann auf verschiedene Arten erfolgen -]. [- Es könnte ein Skript -] oder [- ein automatisierter Dienst eingesetzt werden , der den Füllstand des Speicherplatzes in regelmäßigen Abständen , zum Beispiel alle 15 Minuten oder einmal pro Stunde , prüft . Alternativ kann eine Überprüfung bei einem definierten	[+ Je nach Anwendung und Konfigurationseinstellungen könnten Protokolle auch Daten enthalten +], die [+ dort nicht benötigt werden , z . B . um die Vertraulichkeit +] der [+ Daten zu wahren oder aufgrund von Compliance +]- [+ Anforderungen . Dem kommt eine noch höhere Bedeutung zu , wenn die Protokolle zwischen Institutionen ausgetauscht , oder bei Cloud - Dienstleistern gespeichert oder analysiert werden . Maßnahmen können z . B . Anonymisierung von IP - Adressen oder anderen personenbezogenen Daten oder Geschäftsgeheimnissen , sowie enge Löschfristen sein . Für Verkehrsdaten kann der BfDI Leitfaden Speicherung Verkehrsdaten als Grundlage genutzt werden . Soweit

Attribut	20.04.26	29.05.26
	Schwellenwert durchgeführt werden , etwa wenn 80 % oder 90 % des zugewiesenen Speicherplatzes belegt sind . Zur Behebung könnte bei Kapazitätsengpässen eine automatische Archivierung älterer Protokolldaten auf einem separaten , kostengünstigeren Speicher gestartet werden , um den primären Speicher zu entlasten . Es kann aber auch eine Rotationsstrategie für Log - Dateien konfiguriert werden -], die [- bei Erreichen einer bestimmten Größe oder eines Alters die ältesten Dateien löscht oder archiviert -].	möglich , +] ist [+ es sinnvoll +], die [+ Filterung minimalinvasiv zu gestalten +], [+ d . h . nur diejenigen Daten auszufiltern , deren Speicherung nicht rechtlich +] oder [+ tatsächlich möglich ist +], die [+ restlichen Angaben zum Ergebnis jedoch zu protokollieren +].
Modalverb	SOLLTE	KANN
Parameter	{'det.3.3-prm1': 'bei Erreichen eines bestimmten Schwellwertes oder regelmäßig'}	{'det.3.3-prm1': 'Kriterien'}
Präzisierung	{{bei Erreichen eines bestimmten Schwellwertes oder regelmäßig}}	anhand von {{Kriterien}}
Sicherheitsniveau	normal-SdT	erhöht
Text	Detektion SOLLTE den für die Protokollierung zur Verfügung stehenden Speicherplatz {{ insert: param, det.3.3-prm1 }} überprüfen.	Detektion KANN die Protokollierung nicht benötigter Inhalte anhand von {{ insert: param, det.3.3-prm1 }} einschränken.
Titel	Speicherkapazität	Filterung nicht benötigter Inhalte
UUID	558dc6ab-ba8e-47bb-ba24-ddf09be49ec0	fa239d57-3934-4664-bc2d-53aca634eae
Verwandte		#ASST.3.2

DET.3.4 Speicherkapazität (normal-SdT)

Attribut	20.04.26	29.05.26
Ergebnis	Änderungen am Audit Log	den für die Protokollierung zur Verfügung stehenden Speicherplatz
Handlungswort	dokumentieren	überprüfen
Hinweis	[- Wenn -] die [- Protokollaufzeichnung unzureichend	[+ Diese Vorschrift zielt darauf ab , +] die [+ Verfügbarkeit der Protokolldaten

Attribut	20.04.26	29.05.26
	vor Veränderung geschützt -] ist, [- könnten Innentäter diese manipulieren -] oder [- löschen -], [- um nicht erkannt -] oder [- belangt zu -] werden. [- Hierzu gehört auch -], [- dass Administrierende die -] Protokolldaten [- zu ihren eigenen Tätigkeiten manipulieren oder löschen könnten -]. [- Die Integrität kann durch die Erstellung und getrennte Aufbewahrung von kryptografischen Hashes oder ein Versionskontrollsystem sichergestellt -] werden. Um [- sicherzustellen -], [- dass nur autorisierte Personen die Protokolle verändern können -], [- können z . B . Verschlüsselung und getrennte Aufbewahrung des Schlüssels , einmalig beschreibbare Datenträger , oder ein Protokollierungsserver / SIEM mit stark eingeschränkten Zugriffsrechten eingesetzt -] werden. [- Auch -] die [- Aufzeichnung in -] einer [- öffentlichen Transparenzdatei ist möglich -], [- wenn die Protokolle keine vertraulichen Daten enthalten . -]	sicherzustellen . Das +] ist [+ essenziell +], [+ da eine unterbrochene +] oder [+ lückenhafte Aufzeichnung die Früherkennung von Angriffen unmöglich machen könnte +], [+ was dazu führen könnte , dass kritische forensische Beweise für eine Untersuchung fehlen . Die Umsetzung dieser Anforderung kann auf verschiedene Arten erfolgen . Es könnte ein Skript +] oder [+ ein automatisierter Dienst eingesetzt +] werden, [+ der den Füllstand des Speicherplatzes in regelmäßigen Abständen +], [+ zum Beispiel alle 15 Minuten oder einmal pro Stunde , prüft . Alternativ kann eine Überprüfung bei einem definierten Schwellenwert durchgeführt werden , etwa wenn 80 % oder 90 % des zugewiesenen Speicherplatzes belegt sind . Zur Behebung könnte bei Kapazitätsengpässen eine automatische Archivierung älterer +] Protokolldaten [+ auf einem separaten +], [+ kostengünstigeren Speicher gestartet +] werden, um [+ den primären Speicher zu entlasten +]. [+ Es kann aber auch eine Rotationsstrategie für Log +] [- Dateien konfiguriert +] werden, die [+ bei Erreichen +] einer [+ bestimmten Größe oder eines Alters die ältesten Dateien löscht oder archiviert +].
Parameter		{'det.3.4-prm1': 'bei Erreichen eines bestimmten Schwellwertes oder regelmäßig'}
Präzisierung	revisionssicher	{{bei Erreichen eines bestimmten Schwellwertes oder regelmäßig}}
Tags	Insider Threat	
Text	Detektion SOLLTE Änderungen am Audit Log revisionssicher dokumentieren.	Detektion SOLLTE den für die Protokollierung zur Verfügung stehenden Speicherplatz {{ insert: param, det.3.4-prm1 }} überprüfen.

Attribut	20.04.26	29.05.26
Titel	Revisionssicherheit	Speicherkapazität
UUID	1cd947a7-70a2-41c9-b3fd-90f3ef75838c	558dc6ab-ba8e-47bb-ba24-ddf09be49ec0

DET.3.5 Revisionssicherheit (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	3	4
Ergebnis	Nachweise für den Zusammenhang {{bestimmter Ereignisse}} mit {{einer bestimmten Person oder Rolle}}	Änderungen am Audit Log
Hinweis	[- Für Handlungen -], die [- eine besondere Bedeutung für -] die [- rechtliche Compliance -] oder die [- korrekte Verarbeitung von Daten in kritischen Geschäftsprozessen haben -], [- kann es sinnvoll sein -], [- eine zweifelsfreie Zuordnung -] des [- Ereignisses zu einer Person zu gewährleisten -]. [- Beispiele können das Senden von Nachrichten als Geschäftsleitung -], [- die Überweisung hoher Beträge auf Konten im Ausland -] oder [- der Zugang einer Nachricht -] mit [- großer rechtlicher Bedeutung sein . Für einen zweifelsfreien Nachweis reicht die einfache Zuordnung zu einem Zugangskonto oft nicht aus , da das Konto auch von anderen missbraucht worden sein könnte . Zum Nachweis können verschiedene Maßnahmen -] eingesetzt werden: [- Digitale Signaturen auf Basis asymmetrischer Kryptographie können -] die [- Urheberschaft von Dokumenten verifizieren -], [- während Zeitstempel von vertrauenswürdigen Zeitservern -] die [- chronologische Integrität sicherstellen -]. [- Eine dezentrale Speicherung der Logs auf verschiedenen Systemen erschwert Manipulationsversuche ; ergänzend erhöht die Implementierung einer Blockchain - Technologie mit verketteten	[+ Wenn die Protokollaufzeichnung unzureichend vor Veränderung geschützt ist , könnten Innentäter diese manipulieren oder löschen , um nicht erkannt oder belangt zu werden . Hierzu gehört auch , dass Administrierende die Protokolldaten zu ihren eigenen Tätigkeiten manipulieren oder löschen könnten +]. Die [+ Integrität kann durch +] die [+ Erstellung und getrennte Aufbewahrung von kryptografischen Hashes +] oder [+ ein Versionskontrollsystem sichergestellt werden . Um sicherzustellen , dass nur autorisierte Personen +] die [+ Protokolle verändern können +], [+ können z +]. [+ B . Verschlüsselung und getrennte Aufbewahrung +] des [+ Schlüssels +], [+ einmalig beschreibbare Datenträger +], oder [+ ein Protokollierungsserver / SIEM +] mit [+ stark eingeschränkten Zugriffsrechten +] eingesetzt werden. [+ Auch +] die [+ Aufzeichnung in einer öffentlichen Transparenzdatei ist möglich +], [+ wenn +] die [+ Protokolle keine vertraulichen Daten enthalten +].

Attribut	20.04.26	29.05.26
	Hashwerten die Fälschungssicherheit erheblich . Hardwarebasierte Sicherheitsmodule (HSMs) können kryptografische Schlüssel vor unbefugtem Zugriff schützen . -]	
Modalverb	KANN	SOLLTE
Parameter	{ 'det.3.5-prm1': 'bestimter Ereignisse', 'det.3.5-prm2': 'einer bestimmten Person oder Rolle' }	
Präzisierung		revisionssicher
Sicherheitsniveau	erhöht	normal-SdT
Text	Detektion für Daten KANN Nachweise für den Zusammenhang {{ insert: param, det.3.5-prm1 }} mit {{ insert: param, det.3.5-prm2 }} dokumentieren.	Detektion SOLLTE Änderungen am Audit Log revisionssicher dokumentieren.
Titel	Unbestreitbarkeit	Revisionssicherheit
UUID	1d98ecfc-cf7a-4cf5-a108-169802a7b364	1cd947a7-70a2-41c9-b3fd-90f3ef75838c
Zielobjekte	Daten	

DET.4.5 Unerwünschte Datenabflüsse (erhöht)

Attribut	20.04.26	29.05.26
Aufwand	4	5
Sicherheitsniveau	normal-SdT	erhöht

DET.4.8 Ausstellung neuer HTTPS-Zertifikate (erhöht)

Attribut	20.04.26	29.05.26
Ergebnis	die rechtzeitige Ausstellung neuer HTTPS-Zertifikate für Server, die im Internet erreichbar sind,	die rechtzeitige Ausstellung neuer HTTPS-Zertifikate für Hostsysteme, die im Internet erreichbar sind,
Hinweis	[- Dies kann mittels Certificate Transparency teilautomatisiert	[+ „ Rechtzeitige Ausstellung neuer HTTPS - Zertifikate “ meint +] hier [+ , dass überwacht wird , ob +] vor Ablauf [+ eines bestehenden TLS - / HTTPS - Zertifikats ein neues , gültiges und zur jeweiligen Webserver - Identität passendes Zertifikat

Attribut	20.04.26	29.05.26
	werden . Mit "rechtzeitig " ist -] hier vor Ablauf des [- Zertifikats gemeint . -]	aktiviert wird (certificate expiry monitoring , certificate renewal) . „ HTTPS - Zertifikate “ sind hier X . 509 - Zertifikate für TLS - gesicherte Webverbindungen , die insbesondere Servernamen , Gültigkeitszeitraum , ausstellende Zertifizierungsstelle und kryptografische Bindung an einen Schlüssel enthalten . „ Server , die im Internet erreichbar sind “ bezeichnet Webserver mit öffentlich erreichbarer Adresse oder öffentlich auflösbarem Namen , etwa Webportale , APIs , Kundenportale oder Administrationsoberflächen , sofern sie aus dem Internet angesprochen werden können . Die Vorschrift zielt darauf ab , ablaufende oder nicht rechtzeitig erneuerte Zertifikate frühzeitig sichtbar zu machen : Ein versäumter Austausch könnte zu Browserwarnungen , Dienstunterbrechungen , fehlgeschlagenen API - Verbindungen , Vertrauensverlust bei Nutzenden oder improvisierten Notfallmaßnahmen führen . Eine entsprechende Detektion kann die Verfügbarkeit und Vertrauenswürdigkeit öffentlich erreichbarer Webdienste unterstützen und kann zugleich Hinweise auf Fehlkonfigurationen , unvollständige Automatisierung oder unerwartete Änderungen im Zertifikatsbestand liefern . Hierbei ist es sinnvoll nicht nur die Restlaufzeit mit Schwellwerten zu überwachen , sondern auch die tatsächliche Bereitstellung +] des [+ neuen Zertifikates . Dazu können ein Monitoring der Zertifikatsdaten direkt am Webendpunkt , sowie Auswertungen aus Load - Balancern oder Reverse - Proxys gehören . +]
Text	Detektion für Webserver KANN die rechtzeitige Ausstellung neuer HTTPS-Zertifikate für Server, die im Internet erreichbar sind, überwachen.	Detektion für Webserver KANN die rechtzeitige Ausstellung neuer HTTPS-Zertifikate für Hostsysteme, die im Internet erreichbar sind, überwachen.
Verwandte		#DEV.7.2

DET.4.10 Host-basierte Köder (erhöht)

Attribut	20.04.26	29.05.26
Tags	Zero Trust, Advanced Persistent Threats (APT), Honeypot	Advanced Persistent Threats (APT), Honeypot

DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen (erhöht)

Attribut	20.04.26	29.05.26
Tags	Zero Trust, Advanced Persistent Threats (APT), Command & Control	Advanced Persistent Threats (APT), Command & Control

DET.4.11.2 Netzwerk-Honeypots (erhöht)

Attribut	20.04.26	29.05.26
Tags	Zero Trust, Advanced Persistent Threats (APT), Honeypot	Advanced Persistent Threats (APT), Honeypot

DET.5.3 Schwachstellenscans (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	5	3

DET.5.8.1.1 Unautorisierte Publikation (erhöht)

Attribut	20.04.26	29.05.26
Aufwand	3	5

DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	4	3

DEV.2.6.2 Ausgabekodierung (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	2	3

DEV.7.2 Zertifikatsmonitoring (normal-SdT)

Attribut	20.04.26	29.05.26
Hinweis	[- Anwendungen die -] über [- das Netz kommunizieren nutzen typischerweise X . 509 - Zertifikate -] zur [- Authentifizierung (z . B . per TLS) . Die Ausstellung neuer Zertifikate -] bei [- Zertifizierungsstellen kann ein Angriffsversuch Dritter	[+ Neue Zertifikate sind in diesem Kontext digitale Zertifikate , insbesondere TLS - / Serverzertifikate nach X . 509 , die zu einer von der Anwendung genutzten Domain oder Subdomain ausgestellt werden könnten und deren öffentliche Existenz regelmäßig +] über [+ Certificate - Transparency - Protokolle , Zertifikatsregister oder vergleichbare Quellen erkennbar ist . Von der Anwendung verwendete Domains sind dabei die DNS - Namen , über die die Anwendung selbst

Attribut	20.04.26	29.05.26
	sein , die vorgeben wollen die Anwendung zu betreiben . Dies kann mittels Certificate Transparency automatisiert werden . -]	, ihre Schnittstellen , Weiterleitungen , Mandantenbereiche oder technische Begleitdienste erreichbar sind , etwa Web - Frontends , API - Endpunkte , CDN - oder Load - Balancer - Namen ; fachlich wird häufig von application domains , hostnames , FQDNs oder DNS names gesprochen . Die Vorschrift zielt darauf ab , ungewöhnliche oder unberechtigte Zertifikatsausstellungen frühzeitig erkennbar zu machen , weil eine solche Ausstellung auf Fehlkonfigurationen , kompromittierte DNS - Kontrolle , Missbrauch einer Validierungsmethode oder Vorbereitungen für Phishing - und Man - in - the - Middle - Szenarien hinweisen könnte . Eine entsprechende Beobachtung kann die Zeit bis [+] zur [+] Erkennung verkürzen und ermöglichen , betroffene Domains , Zertifizierungsstellen , DNS - Einträge oder Validierungswege gezielt zu prüfen , bevor Nutzende oder technische Clients einer täuschend echt wirkenden Gegenstelle vertrauen . Hierzu ist es sinnvoll Abfragen öffentlicher Certificate - Transparency - Logs für definierte FQDNs und Wildcards , Alarmierungen [+] bei [+] neuen Zertifikaten außerhalb erwarteter Aussteller oder Namensmuster , sowie regelmäßige Abgleiche einer gepflegten Domainliste mit neu beobachteten Zertifikatseinträgen zu verwenden . +]
Verwandte		#DET.4.8

GEB.5.1 Lieferzugang (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	3	4
Dokumentation	Arbeitsanweisung	Gebäudedokumentation
Ergebnis	zum Aufräumen von vertraulichen Dokumenten und Datenträgern	einen Zugang für die Abwicklung von Lieferungen
Handlungswort	anweisen	installieren
Hinweis	Ein [- aufgeräumter Arbeitsplatz („ Clean Desk Policy “) -] kann [- dazu beitragen , Informationssicherheit und Datenschutz am Arbeitsplatz -] zu [- stärken , indem sie verhindert , dass vertrauliche Unterlagen , Datenträger oder -]	Ein [+ Zugang für die Abwicklung von Lieferungen ist ein baulich abgegrenzter Bereich (engl . delivery access point) , der es ermöglicht , Waren , Material oder technische Geräte geschützt vor sonstigen äußeren Einflüssen anzunehmen bzw . abzugeben , ohne dass Lieferpersonal oder

Attribut	20.04.26	29.05.26
	elektronische [- Geräte unbefugt eingesehen oder entwendet werden . Durch konsequentes Aufräumen am Ende des Arbeitstages oder bei längeren Abwesenheiten kann das Risiko von Datenlecks , Industriespionage oder versehentlicher Offenlegung sensibler Informationen minimiert werden . Gleichzeitig kann eine aufgeräumte Arbeitsumgebung die Konzentration und Effizienz der Mitarbeitenden fördern , da unnötige Ablenkungen reduziert werden und das Wiederfinden wichtiger Unterlagen beschleunigt wird . Hierzu gehören sowohl physische Unterlagen wie Akten , Notizzettel oder Ausdrücke -] mit [- personenbezogenen oder geschäftskritischen Daten , als auch elektronische Datenträger oder Bildschirminhalte . -]	externe Dienstleister unkontrollierten Zutritt zu sicherheitsrelevanten Bereichen in der Institution erhalten . Unbefugter Zugang meint hierbei jeden Zutritt durch Personen , die für den betroffenen Standort oder bestimmte Schutzbereiche keine Zutrittsberechtigung besitzen (engl . unauthorized access) . Der Sinn dieser Vorgabe liegt darin , Risiken durch unkontrollierte physische Zugänge zu minimieren : Ein Lieferant könnte etwa versehentlich oder absichtlich in interne Büro - oder Technikbereiche gelangen und dadurch vertrauliche Informationen , IT - Geräte oder Zugangsdaten einsehen oder entwenden . Eine bauliche und organisatorische Trennung +] kann [+ dagegen gewährleisten , dass Lieferungen gesteuert angenommen , geprüft und weiterverarbeitet werden , ohne sicherheitskritische Bereiche +] zu [+ gefährden . Beispielsweise kann es je nach Standort sinnvoll sein : (1) separate Schleusen - oder Annahmebereiche mit kontrollierter Türverriegelung , (2) Gegensprechanlagen oder Kameraeinrichtungen zur Identifikation von Lieferanten , (3) zeitlich begrenzte oder zonenbeschränkte Zutrittsberechtigungen über +] elektronische [+ Zugangssysteme , sowie (4) baulich getrennte Lieferzonen +] mit [+ Sichtschutz und gesichertem Übergabepunkt einzurichten . +]
Präzisierung	vor dem Verlassen des Arbeitsplatzes	ohne unbefugten Zugang zum restlichen Standort
Text	Gebäudemanagement für Räume SOLLTE zum Aufräumen von vertraulichen Dokumenten und Datenträgern vor dem Verlassen des Arbeitsplatzes anweisen.	Gebäudemanagement für Standorte SOLLTE einen Zugang für die Abwicklung von Lieferungen ohne unbefugten Zugang zum restlichen Standort installieren.
Titel	Clean Desk	Lieferzugang
UUID	b5fcf9c6-b6e5-4018-bb9b-64344a2e0a4e	bf559e67-d53f-4ef3-928b-5d9774e7b87c

Attribut	20.04.26	29.05.26
Zielobjekte	Räume	Standorte

GEB.5.2 Schutz gegen Manipulation (erhöht)

Attribut	20.04.26	29.05.26
Aufwand	3	5
Dokumentation	Arbeitsanweisung	Betriebshandbuch
Ergebnis	zum Sperren von IT-System	Manipulationsschutzvorkehrungen
Handlungswort	anweisen	installieren
Hinweis	[- Diese Vorgehensweise hilft dabei , unbefugten Zugriff -] auf [- sensible Informationen zu -] verhindern, [- die -] auf [- dem Bildschirm angezeigt werden könnten . Ansonsten könnte es zu unbefugten Zugriffen auf Daten oder die Systeme selber kommen , wenn diese unbewacht und ungesperrt zurückgelassen werden . -]	[+ Manipulationsschutzvorkehrungen sind physische oder technische Schutzmaßnahmen („ tamper protection measures “) , die darauf ausgelegt sind , unbefugte Eingriffe , Veränderungen oder Beschädigungen an IT - Systemen oder deren Infrastruktur frühzeitig zu verhindern oder zumindest erkennbar zu machen . Der Begriff „ gemeinsame Arbeitsbereiche “ („ shared workspaces “) umfasst Räumlichkeiten , in denen mehrere Personen , Teams oder Abteilungen gleichzeitig arbeiten , wodurch sich naturgemäß ein erhöhtes Risiko unkontrollierter Zugriffe +] auf [+ technische Einrichtungen ergibt . Der Zweck dieser Anforderung liegt darin , die Integrität und Verfügbarkeit der eingesetzten Systeme zu wahren und Manipulationen vorzubeugen , die durch unbeaufsichtigte physische Zugriffe oder verdeckte Eingriffe erfolgen könnten . Ein ungeschütztes Gerät in einem frei zugänglichen Raum könnte beispielsweise durch das unbemerkte Einstecken manipulierter USB - Geräte oder das Entfernen von Netzkabeln kompromittiert werden , während ein gezielter Eingriff in eine Serversteckdose zu Systemausfällen führen könnte . Eine Manipulationsschutzvorkehrung kann hier den Nachweis eines Eingriffs ermöglichen oder diesen bereits im Ansatz +] verhindern. [+ Beispielsweise kann sinnvoll sein : (1) die Verwendung manipulationssicherer Gehäuse oder Gehäusesiegel , (2) der Einsatz von abschließbaren IT - Racks oder gesicherten Anschlussfeldern , (3) die Integration physischer Sensoren , die bei Gehäuseöffnung Alarmmeldungen erzeugen , oder (4) die

Attribut	20.04.26	29.05.26
		Kennzeichnung und regelmäßige Sichtprüfung von Geräten +] auf [+ Manipulationsspuren . Auch der gezielte Einbau von IT - Komponenten in erhöhten , kameragesicherten oder besonders einsehbaren Bereichen kann eine praktikable Schutzwirkung entfalten . +]
Modalverb	SOLLTE	KANN
Präzisierung	vor dem Verlassen des Arbeitsplatzes	
Sicherheitsniveau	normal-SdT	erhöht
Text	Gebäudemanagement für Räume SOLLTE zum Sperren von IT-System vor dem Verlassen des Arbeitsplatzes anweisen.	Gebäudemanagement für IT-Systeme KANN Manipulationsschutzvorkehrungen installieren.
Titel	Screen Lock	Schutz gegen Manipulation
UUID	56f4e238-cbce-4353-b4a8-bc3ee1c665c5	59810143-17bf-49b6-91d0-1266cb7eb9da
Zielobjekte	Räume	IT-Systeme

GEB.5.3 Physische Mikrosegmentierung (erhöht)

Attribut	20.04.26	29.05.26
Aufwand	4	5
Ergebnis	einen Zugang für die Abwicklung von Lieferungen	eine physische Mikrosegmentierung
Hinweis	[- Ein Zugang für die Abwicklung von Lieferungen ist ein baulich abgegrenzter Bereich (engl . delivery access point) , -] der [- es ermöglicht , Waren , Material oder technische Geräte geschützt vor sonstigen äußeren Einflüssen anzunehmen bzw . abzugeben , ohne dass Lieferpersonal oder externe Dienstleister unkontrollierten Zutritt zu sicherheitsrelevanten Bereichen -] in der [- Institution erhalten -]. [- Unbefugter Zugang meint hierbei	[+ Bei +] der [+ physischen Mikrosegmentierung +] in der [+ Sicherheitsarchitektur geht es darum +], [+ unterschiedliche physische Grenzen innerhalb gemeinsam genutzter Einrichtungen zu schaffen +], [+ um verschiedene Sicherheitsbereiche zu isolieren und zu schützen . Dies ist besonders wichtig für Umgebungen , in denen Assets mit verschiedenen Sicherheitseigenschaften nebeneinander existieren . Bei dieser Strategie werden bauliche Maßnahmen eingesetzt , wie z . B . getrennte Eingänge , dedizierte

Attribut	20.04.26	29.05.26
	jeden Zutritt durch Personen -], die [- für den betroffenen Standort oder bestimmte Schutzbereiche keine Zutrittsberechtigung besitzen (engl . unauthorized access) . Der Sinn dieser Vorgabe liegt darin , Risiken durch unkontrollierte physische Zugänge -] zu [- minimieren : Ein Lieferant könnte etwa versehentlich oder absichtlich in interne Büro - oder Technikbereiche gelangen -] und [- dadurch vertrauliche Informationen , IT - Geräte oder Zugangsdaten einsehen oder entwenden . Eine bauliche und organisatorische Trennung kann dagegen -] gewährleisten, [- dass Lieferungen gesteuert angenommen -], [- geprüft -] und [- weiterverarbeitet werden -], [- ohne sicherheitskritische Bereiche zu gefährden -]. [- Beispielsweise kann es je nach Standort sinnvoll -] sein: [- (1) separate Schleusen - oder Annahmebereiche mit kontrollierter Türverriegelung , (2) Gegensprechanlagen oder Kameraeinrichtungen zur Identifikation von Lieferanten , (3) zeitlich begrenzte oder zonenbeschränkte Zutrittsberechtigungen über elektronische Zugangssysteme , sowie (4) baulich getrennte Lieferzonen mit Sichtschutz und gesichertem Übergabepunkt einzurichten . -]	Versorgungssysteme , Fallen , abgeschottete HLK - Anlagen , physisch getrennte Netzwerkinfrastrukturen und zugangskontrollierte Zonen , um +] die [+ seitliche Bewegung von Bedrohungen +] zu [+ verhindern +] und [+ gleichzeitig die Einhaltung von Vorschriften zu +] gewährleisten. [+ Zu den üblichen Anwendungen gehören Bürogebäude mit mehreren Mietparteien +], [+ in denen verschiedene Institutionen eine Trennung benötigen , Colocation - Rechenzentren mit kundenspezifischer Geräteisolierung , gemeinsam genutzte Regierungseinrichtungen mit unterschiedlichen Klassifizierungsanforderungen +] und [+ Campus +]- [+ Umgebungen +], [+ in denen miteinander verbundene Gebäude unterschiedliche Sicherheitsperimeter aufrechterhalten müssen - all dies unterstützt ein umfassendes Risikomanagement und die Eindämmung von Vorfällen . Maßnahmen können z . B . intelligenten Schlössern an Käfigtüren und Sensoren an den Seitenwänden von Serverracks +] sein.
Modalverb	SOLLTE	KANN
Präzisierung	ohne unbefugten Zugang zum restlichen Standort	
Sicherheitsniveau	normal-SdT	erhöht

Attribut	20.04.26	29.05.26
Text	Gebäudemanagement für Standorte SOLLTE einen Zugang für die Abwicklung von Lieferungen ohne unbefugten Zugang zum restlichen Standort installieren.	Gebäudemanagement für IT-Systeme KANN eine physische Mikrosegmentierung installieren.
Titel	Lieferzugang	Physische Mikrosegmentierung
UUID	bf559e67-d53f-4ef3-928b-5d9774e7b87c	ae6ec98f-fe6f-4334-904c-9f17235c45e5
Zielobjekte	Standorte	IT-Systeme

GEB.7.2 Verwahrung von Schlüsseln (normal-SdT)

Attribut	20.04.26	29.05.26
Text	Gebäudemanagement für Standorte SOLLTE zur Verwahrung von Schlüsseln anweisen.	Gebäudemanagement für Nutzende von Standorten SOLLTE zur Verwahrung von Schlüsseln anweisen.
Zielobjekte	Standorte	Nutzende, Standorte

GEB.10.2 Brandschutz (normal-SdT)

Attribut	20.04.26	29.05.26
Verbesserung	GEB.10.2.1, GEB.10.2.2, GEB.10.2.3, GEB.10.2.4, GEB.10.2.5, GEB.10.2.6, GEB.10.2.7, GEB.10.2.8	GEB.10.2.1, GEB.10.2.2, GEB.10.2.3, GEB.10.2.4, GEB.10.2.5, GEB.10.2.6, GEB.10.2.7
Verwandte		#SENS.8.10

GEB.10.2.5 Brandmeldeanlagen (normal-SdT)

Attribut	20.04.26	29.05.26
Dokumentation	Arbeitsanweisung	Gebäudedokumentation
Ergebnis	das ungesicherte Hinterlassen von Brandlasten	das Entstehen von Bränden
Handlungswort	untersagen	überwachen

Attribut	20.04.26	29.05.26
Hinweis	[- Befinden sich Brandlasten wie Kartons -], [- brennbare Dämmstoffe -], [- Batterien oder Holzmöbel in der Nähe -] ([- oder sogar in) Räumen für technische Infrastruktur oder zentraler Versorgungseinrichtungen , so erhöhen sich Wahrscheinlichkeit und durchschnittliches Schadensausmaß von Bränden . Dies gilt auch für das Rauchen von Zigaretten oder Zigarren . Der einzuhaltende Abstand ergibt sich aus der Größe der Brandlast und dem Schutzbedarf des Ortes von dem Abstand zu halten ist - wenn möglich ist ein Abstand von mindestens einem Zwischenraum sinnvoll . -]	[+ Die Umsetzung kann durch Brandmeldezentralen oder dezentrale Brandmeldealarmierung erfolgen +], [+ siehe DIN EN 54 und DIN VDE 0833 +]- [+ 2 +].
Text	Gebäudemanagement für Standorte SOLLTE das ungesicherte Hinterlassen von Brandlasten untersagen.	Gebäudemanagement für Standorte SOLLTE das Entstehen von Bränden überwachen.
Titel	Vermeidung von Brandlasten	Brandmeldeanlagen
UUID	3c49b485-9113-4009-a2dc-598c9d9a3f5f	92dfd98d-40ed-4854-a3d8-00a84fe77cec

GEB.10.2.6 Brandunterdrückung (erhöht)

Attribut	20.04.26	29.05.26
Aufwand	3	5
Ergebnis	das Entstehen von Bränden	Brandunterdrückungssysteme
Handlungswort	überwachen	installieren
Hinweis	[- Die Umsetzung -] kann durch [- Brandmeldezentralen oder dezentrale Brandmeldealarmierung erfolgen -], siehe [- DIN EN 54 und DIN VDE 0833 -] [- 2 -].	Kann [+ z . B . +] durch [+ eine Anlage zur Sauerstoffreduktion unter 15 Volumenprozent umgesetzt werden , da Feuer sich so kaum entzünden kann +]. Siehe [+ ISO 20338 +]. [+ Denken Sie dabei auch an den Schutz des Personals +], [+ siehe Arbeitstättenverordnung (ArbStättV) . +]
Modalverb	SOLLTE	KANN
Sicherheitsniveau	normal-SdT	erhöht
Text	Gebäudemanagement für Standorte SOLLTE das Entstehen von Bränden überwachen.	Gebäudemanagement für Serverräume KANN Brandunterdrückungssysteme installieren.

Attribut	20.04.26	29.05.26
Titel	Brandmeldeanlagen	Brandunterdrückung
UUID	92dfd98d-40ed-4854-a3d8-00a84fe77cec	7520aa89-9296-4ae3-a60d-5c781dd06732
Zielobjekte	Standorte	Serverräume

GEB.10.2.7 Brandschutzprüfung (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	5	3
Dokumentation	Gebäudedokumentation	Übungs- und Prüfplan
Ergebnis	Brandunterdrückungssysteme	die Wirksamkeit der Brandschutzmaßnahmen
Handlungswort	installieren	überprüfen
Hinweis	[- Kann z -]. [- B -]. [- durch eine Anlage zur Sauerstoffreduktion unter 15 Volumenprozent umgesetzt werden -]. [- da Feuer sich so kaum entzünden kann -]. [- Siehe ISO 20338 -]. [- Denken Sie dabei auch an den Schutz des Personals -]. [- siehe Arbeitstättenverordnung (ArbStättV) . -]	[+ Eine regelmäßige Überprüfung von Brandmeldeanlagen +], [+ Rauchmeldern und organisatorische Maßnahmen stellt sicher +], [+ dass diese weiterhin funktionieren +]. [+ Hier besteht ein enger Zusammenhang zu Compliance +]- [+ Verpflichtungen +], [+ die Brandschutzprüfungen fordern +].
Modalverb	KANN	SOLLTE
Parameter		{'geb.10.2.7-prm1': 'regelmäßig'}
Präzisierung		{{regelmäßig}}
Sicherheitsniveau	erhöht	normal-SdT
Tags		Inspektion
Text	Gebäudemanagement für Serverräume KANN Brandunterdrückungssysteme installieren.	Gebäudemanagement für Standorte SOLLTE die Wirksamkeit der Brandschutzmaßnahmen {{ insert: param, geb.10.2.7-prm1 }} überprüfen.
Titel	Brandunterdrückung	Brandschutzprüfung
UUID	7520aa89-9296-4ae3-a60d-5c781dd06732	3b904a6b-c440-4360-ab4a-37b76fc639a7
Zielobjekte	Serverräume	Standorte

KONF.2.5 Überprüfung der Konfiguration (normal-SdT)

Attribut	20.04.26	29.05.26
Verbesserung	KONF.2.5.1, KONF.2.5.1.1	KONF.2.5.1

KONF.2.5.1 Automatische Konfigurationsverwaltung (erhöht)

Attribut	20.04.26	29.05.26
Verbesserung	KONF.2.5.1.1	

KONF.2.6 Automatische Konfigurationsverwaltung (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	5	3
Dokumentation	IT-Betriebskonzept	Konfigurationshistorie
Ergebnis	Souveräne Werkzeuge	die Verwaltung durch ein Mobile Device Management (MDM)
Handlungswort	installieren	aktivieren
Hinweis	[- „ Souveräne Werkzeuge “ -] sind [- Anwendungen -], [- Systeme und physische Werkzeuge , die technisch , rechtlich und organisatorisch unabhängig von externen Herstellern , Cloud - Anbietern oder staatlicher Einflussnahme betrieben werden können . Das umfasst vor allem Lösungen , die lokal kontrollierbar und ohne zwingende Abhängigkeit zu externen Plattformen nutzbar sind . Der Sinn der Vorschrift liegt darin , die Handlungsfähigkeit und Sicherheit der Institution zu stärken : Ein rein cloudbasierter Konfigurationsdienst könnte durch einen plötzlichen Ausfall , eine staatlich erzwungene Sperrung oder durch nachträglich geänderte Lizenzbedingungen die Betriebsfähigkeit gefährden . Die Nutzung souveräner Werkzeuge kann dagegen die Verfügbarkeit kritischer Systeme erhöhen , die Datenhoheit bewahren und Manipulationsmöglichkeiten von Dritten minimieren . Souveräne	[+ Die Konfigurationsanforderungen für Mobile Device Management (MDM) +] sind [+ im BSI +]- [+ Mindeststandard für MDM umfassend beschrieben +]. Es [+ ist empfehlenswert +], [+ diese Mindestanforderungen heranzuziehen +]. Ergänzend [+ wird empfohlen +], [+ sicherheitsrelevante Kriterien bereits bei der Produktauswahl zu berücksichtigen , +] vertrauenswürdige [+ Apps durch Reputationsdienste zu prüfen +], [+ kompromittierte Geräte (z . B . durch Jailbreak oder Root) automatisiert zu erkennen +] und [+ Geofencing zur kontextbezogenen Richtliniendurchsetzung einzusetzen +].

Attribut	20.04.26	29.05.26
	Konfigurationssysteme machen unabhängig vor Ausfällen , Datenschutzverletzungen oder einseitigen Änderungen der Nutzungsbedingungen durch externe Dienstleister . Eine Institution kann diese Anforderung beispielsweise so umsetzen : (1 -) Es [- kann auf quelloffene Konfigurations -] - [- Frameworks zurückgegriffen werden , die lokal installiert und betrieben werden . (2) Virtualisierte oder containerisierte Varianten dieser Werkzeuge werden in der eigenen Infrastruktur betrieben , sodass keine unkontrollierten externen Abhängigkeiten entstehen . (3 -)] Ergänzend [- kann ein internes Repository für Konfigurationsmodule eingerichtet werden -], [- um eine -] vertrauenswürdige, [- geprüfte -] und [- nachvollziehbare Quellenbasis sicherzustellen -].	
Modalverb	KANN	SOLLTE
Sicherheitsniveau	erhöht	normal-SdT
Tags	Hochverfügbarkeit	
Text	Konfiguration für IT-Systeme KANN Souveräne Werkzeuge installieren.	Konfiguration für Endgeräte SOLLTE die Verwaltung durch ein Mobile Device Management (MDM) aktivieren.
Titel	Souveräne Werkzeuge	Automatische Konfigurationsverwaltung
UUID	9b18fd2e-8300-49d5-b244-88df6674c5c6	c209d678-2ee3-48f9-8fce-016b4f49481c
Zielobjekte	IT-Systeme	Endgeräte

KONF.2.7 Souveräne Werkzeuge (erhöht)

Attribut	20.04.26	29.05.26
Ergebnis	alternative Administrationszugänge	Souveräne Werkzeuge
Hinweis	Das [- ist zum Beispiel -] von [- Bedeutung bei zentralen Systemen wie Firewalls und Router , bei deren	[+ „ Souveräne Werkzeuge “ sind Anwendungen , Systeme und physische Werkzeuge , die technisch , rechtlich und organisatorisch

Attribut	20.04.26	29.05.26
	Ausfall -] eine [- Fernwartung nicht mehr möglich ist . Hierzu können alternative Werkzeuge , sowie alternative Protokolle , Schnittstellen und Zugangskonten verwendet werden . Alternative Werkzeuge sind z . B . Kommandozeilenwerkzeuge , API - Schnittstellen oder die Konsole virtualisierter oder physischer Server , statt der Grafischen Benutzeroberfläche . Bei Cloud - Diensten kann dies z . B . durch Vorhalten von sowohl Browser - Zugang als auch CLI - Zugang geschehen . Alternative Zugangskonten sind z . B Break - Glass - Accounts , deren Zugangsdaten nur bei Notfällen aus einem Safe entnommen werden . -]	unabhängig von externen Herstellern , Cloud - Anbietern oder staatlicher Einflussnahme betrieben werden können . +] Das [+ umfasst vor allem Lösungen , die lokal kontrollierbar und ohne zwingende Abhängigkeit zu externen Plattformen nutzbar sind . Der Sinn der Vorschrift liegt darin , die Handlungsfähigkeit und Sicherheit der Institution zu stärken : Ein rein cloudbasierter Konfigurationsdienst könnte durch einen plötzlichen Ausfall , eine staatlich erzwungene Sperrung oder durch nachträglich geänderte Lizenzbedingungen die Betriebsfähigkeit gefährden . Die Nutzung souveräner Werkzeuge kann dagegen die Verfügbarkeit kritischer Systeme erhöhen , die Datenhoheit bewahren und Manipulationsmöglichkeiten +] von [+ Dritten minimieren . Souveräne Konfigurationssysteme machen unabhängig vor Ausfällen , Datenschutzverletzungen oder einseitigen Änderungen der Nutzungsbedingungen durch externe Dienstleister . +] Eine [+ Institution kann diese Anforderung beispielsweise so umsetzen : (1) Es kann auf quelloffene Konfigurations - Frameworks zurückgegriffen werden , die lokal installiert und betrieben werden . (2) Virtualisierte oder containerisierte Varianten dieser Werkzeuge werden in der eigenen Infrastruktur betrieben , sodass keine unkontrollierten externen Abhängigkeiten entstehen . (3) Ergänzend kann ein internes Repository für Konfigurationsmodule eingerichtet werden , um eine vertrauenswürdige , geprüfte und nachvollziehbare Quellenbasis sicherzustellen . +]
Text	Konfiguration für IT-Systeme KANN alternative Administrationszugänge installieren.	Konfiguration für IT-Systeme KANN Souveräne Werkzeuge installieren.
Titel	Alternative Administrationszugänge	Souveräne Werkzeuge
UUID	076ffb7b-6f9e-4f71-8752-cfaa290ee306	9b18fd2e-8300-49d5-b244-88df6674c5c6

KONF.2.8 Alternative Administrationszugänge (erhöht)

Attribut	20.04.26	29.05.26
Dokumentation	Konfigurationshistorie	IT-Betriebskonzept
Ergebnis	einen abgesicherten und authentisierten Bootprozess	alternative Administrationszugänge
Handlungswort	aktivieren	installieren
Hinweis	[- Dies empfiehlt sich für eingebettete Systeme -] ([- Embedded Systems -]), [- indem -] z. B. der [- Bootloader die Integrität des Betriebssystems überprüft und es nur dann lädt , wenn es als korrekt eingestuft wurde . Ebenso empfiehlt es sich ein mehrstufiges Boot - Konzept mit kryptographisch sicherer Überprüfung der Einzelschritte zu realisieren , sichere Hardware - Vertrauensanker zu verwenden -], bei [- ARM -]& [- UEFI -] [- basierten Systemem jeweils -] ([- ARM -]) [- Secure Boot zu nutzen -]. [+ Das ist zum Beispiel von Bedeutung bei zentralen Systemen wie Firewalls und Router +], [+ bei deren Ausfall eine Fernwartung nicht mehr möglich ist +]. [+ Hierzu können alternative Werkzeuge +], [+ sowie alternative Protokolle , Schnittstellen und Zugangskonten verwendet werden . Alternative Werkzeuge sind +] z. B. [+ Kommandozeilenwerkzeuge , API - Schnittstellen oder die Konsole virtualisierter oder physischer Server , statt +] der [+ Grafischen Benutzeroberfläche +]. Bei [+ Cloud +]- [+ Diensten kann dies z +]. [+ B +]. [+ durch Vorhalten von sowohl Browser +]- [+ Zugang als auch CLI +]- [+ Zugang geschehen . Alternative Zugangskonten sind z . B Break - Glass - Accounts , deren Zugangsdaten nur bei Notfällen aus einem Safe entnommen werden . +]	
Tags	Cryptography, Produktbeschreibung	Hochverfügbarkeit
Text	Konfiguration für IT-Systeme KANN einen abgesicherten und authentisierten Bootprozess aktivieren.	Konfiguration für IT-Systeme KANN alternative Administrationszugänge installieren.
Titel	Abgesicherter und authentisierter Bootprozess	Alternative Administrationszugänge
UUID	8d460d82-f7db-42c5-b213-625df4381ff3	076ffb7b-6f9e-4f71-8752-cfaa290ee306

KONF.6.5 Dynamische Zugriffskontrolle im System (erhöht)

Attribut	20.04.26	29.05.26
Tags	Produktbeschreibung, Zero Trust	Produktbeschreibung

KONF.11.1 Authentifizierung vor dem Zugriff (normal-SdT)

Attribut	20.04.26	29.05.26
Tags	Produktbeschreibung, Zero Trust	Produktbeschreibung

KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig (normal-SdT)

Attribut	20.04.26	29.05.26
Tags	Produktbeschreibung, Zero Trust	Produktbeschreibung

KONF.14.1 Verschlüsselung beim Transport (normal-SdT)

Attribut	20.04.26	29.05.26
Tags	Produktbeschreibung, Cryptography, Zero Trust	Produktbeschreibung, Cryptography

KONF.14.1.2 Ende-zu-Ende-Verschlüsselung (erhöht)

Attribut	20.04.26	29.05.26
Tags	Produktbeschreibung, Cryptography, Zero Trust	Produktbeschreibung, Cryptography

REA.2.5 IT-Forensik (erhöht)

Attribut	20.04.26	29.05.26
Modalverb	KANN	SOLLTE
Text	Sicherheitsvorfallsbehandlung KANN eine forensische Analyse bei Vorfällen, die {{ insert: param, rea.2.5-prm1 }} erfüllen, ausführen.	Sicherheitsvorfallsbehandlung SOLLTE eine forensische Analyse bei Vorfällen, die {{ insert: param, rea.2.5-prm1 }} erfüllen, ausführen.

SENS.4.1.5 Biometrische Authentifikation (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	1	3

SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	2	3

SENS.8.1 Screen Lock (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	1	3
Ergebnis	gegen Risiken der Nutzung von mobilen Endgeräten	zum Sperren von IT-System
Handlungswort	sensibilisieren	anweisen
Hinweis	[- Bei der Nutzung mobiler Endgeräte wie Smartphones -, [- Tablets -] und [- Laptops ist Vorsicht geboten , da diese Geräte häufig außerhalb gesicherter Umgebungen betrieben werden und dort typischerweise einer höheren Gefährdungslage ausgesetzt sind . Beispiele sind z . B . Abhandenkommen von Geräten oder Zugang von Unbefugten zu Informationen im öffentlichen Verkehr . Durch den konsequenten Einsatz von Gerätesperren , Verschlüsselung , vertrauenswürdigen Netzwerken sowie der geschützten Verwahrung von Geräten kann das Risiko einer unbefugten Nutzung erheblich reduziert -] werden.	[+ Diese Vorgehensweise hilft dabei +], [+ unbefugten Zugriff auf sensible Informationen zu verhindern , die auf dem Bildschirm angezeigt werden könnten . Ansonsten könnte es zu unbefugten Zugriffen auf Daten oder die Systeme selber kommen , wenn diese unbewacht +] und [+ ungesperrt zurückgelassen +] werden.
Präzisierung		vor dem Verlassen des Arbeitsplatzes
Text	Sensibilisierung für Nutzende von Endgeräten SOLLTE gegen Risiken der Nutzung von mobilen Endgeräten sensibilisieren.	Sensibilisierung für Nutzende SOLLTE zum Sperren von IT-System vor dem Verlassen des Arbeitsplatzes anweisen.
Titel	Risiken der Nutzung von mobilen Endgeräten	Screen Lock
UUID	d3d8d31b-bbc8-4e63-9f09-4dc19897323c	56f4e238-cbce-4353-b4a8-bc3ee1c665c5
Verwandte	#ASST.6.1	
Zielobjekte	Nutzende, Endgeräte	Nutzende

SENS.8.2 Clean Desk (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	2	3
Ergebnis	zum Verschließen von Fenstern und Türen	zum Aufräumen von vertraulichen Dokumenten und Datenträgern
Hinweis	[- Durch unverschlossene Türen -] und [- Fenster könnten Unbefugte Zutritt	[+ Ein aufgeräumter Arbeitsplatz („ Clean Desk Policy “) kann dazu

Attribut	20.04.26	29.05.26
	erlangen und -] ([- in Außenwänden -]) [- auch Umwelteinflüsse wirksam -] werden ([- Regen -], [- Sturm -], [- Frost -]) [- , so dass IT , sensible Informationen -] und [- andere Werte in Gefahr geraten , zerstört , beschädigt , ausgespäht oder entfernt werden könnten . Sobald die Anwesenheit von Pesonen in einem Raum endet , sind Türen und Fenster daher so zu schließen , dass von Außen -] das [- unbefugte Öffnen und (in Außenwänden) das Eindringen von Umwelteinflüssen verhindert -] wird. [- Türen werden z -]. [- B -]. [- abgeschlossen -] oder [- Türschließsysteme in den entsprechenden Betriebszustand gebracht -], [- Fenster ganz geschlossen und verriegelt . Nicht erforderlich ist das Verschließen der Türen von fensterlosen Innenräumen , in denen keine IT , sensible Informationen oder andere Werte aufbewahrt werden , oder wenn Risiken praktisch ausgeschlossen werden können (z . B . Kippen von Außenfenstern in höheren Geschossen bei gutem Wetter vor kurzer Abwesenheit) . Dies gilt auch für Gemeinschaftsräume , in denen sich IT - Systeme oder Datenträger befinden , z . B . VK - Konferenzzimmer . -]	beitragen , Informationssicherheit +] und [+ Datenschutz am Arbeitsplatz zu stärken +], [+ indem sie verhindert +], [+ dass vertrauliche Unterlagen , Datenträger oder elektronische Geräte unbefugt eingesehen oder entwendet +] werden. [+ Durch konsequentes Aufräumen am Ende des Arbeitstages oder bei längeren Abwesenheiten kann das Risiko von Datenlecks +], [+ Industriespionage oder versehentlicher Offenlegung sensibler Informationen minimiert werden +]. [+ Gleichzeitig kann eine aufgeräumte Arbeitsumgebung die Konzentration und Effizienz der Mitarbeitenden fördern +], [+ da unnötige Ablenkungen reduziert werden +] und das [+ Wiederfinden wichtiger Unterlagen beschleunigt +] wird. [+ Hierzu gehören sowohl physische Unterlagen wie Akten +], [+ Notizzettel oder Ausdrucke mit personenbezogenen oder geschäftskritischen Daten +], [+ als auch elektronische Datenträger +] oder [+ Bildschirminhalte +].
Präzisierung	beim Verlassen von Räumlichkeiten	vor dem Verlassen des Arbeitsplatzes
Tags	Physical Access Control	
Text	Sensibilisierung für Nutzende von Gebäuden SOLLTE zum Verschließen von Fenstern und Türen beim Verlassen von Räumlichkeiten anweisen.	Sensibilisierung für Nutzende SOLLTE zum Aufräumen von vertraulichen Dokumenten und Datenträgern vor dem Verlassen des Arbeitsplatzes anweisen.
Titel	Schließen von Türen und Fenstern	Clean Desk
UUID	2a761948-b26a-4e19-8a9d-75f78ac19811	b5fcf9c6-b6e5-4018-bb9b-64344a2e0a4e
Zielobjekte	Nutzende, Gebäude	Nutzende

SENS.8.3 Risiken der Nutzung von mobilen Endgeräten (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	5	1
Ergebnis	das Mitbringen unautorisierter IT-Systeme	gegen Risiken der Nutzung von mobilen Endgeräten
Handlungswort	untersagen	sensibilisieren
Hinweis	[- Fremde IT -] [- Systeme -] sind [- ein Risiko -], [- weil sie an das interne Netz angeschlossen -], [- zum Mithören von Gesprächen oder zur Standortverfolgung missbraucht werden können -]. [- Relevant sind dabei sowohl Geräte der Mitarbeitenden , als auch von Externen . Dies kann auch durch eine Hinterlegung -] von Geräten [- an -] der [- Pforte oder in verschließbaren Fächern am Eingang umgesetzt -] werden. [+ Bei der Nutzung mobiler Endgeräte wie Smartphones +], [+ Tablets und Laptops ist Vorsicht geboten , da diese Geräte häufig außerhalb gesicherter Umgebungen betrieben werden und dort typischerweise einer höheren Gefährdungslage ausgesetzt +] sind. [+ Beispiele sind z +]. [+ B +]. [+ Abhandenkommen +] von Geräten [+ oder Zugang von Unbefugten zu Informationen im öffentlichen Verkehr . Durch den konsequenten Einsatz von Gerätesperren , Verschlüsselung , vertrauenswürdigen Netzwerken sowie +] der [+ geschützten Verwahrung von Geräten kann das Risiko einer unbefugten Nutzung erheblich reduziert +] werden.	
Modalverb	KANN	SOLLTE
Sicherheitsniveau	erhöht	normal-SdT
Tags	Bring Your Own Device	
Text	Sensibilisierung für Nutzende KANN das Mitbringen unautorisierter IT-Systeme untersagen.	Sensibilisierung für Nutzende von Endgeräten SOLLTE gegen Risiken der Nutzung von mobilen Endgeräten sensibilisieren.
Titel	Mitbringen von IT-Systemen	Risiken der Nutzung von mobilen Endgeräten
UUID	6988844b-ed26-4ad3-83f6-ba5cf223070b	d3d8d31b-bbc8-4e63-9f09-4dc19897323c
Verwandte		#ASST.6.1
Zielobjekte	Nutzende	Nutzende, Endgeräte

SENS.8.4 Schließen von Türen und Fenstern (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	4	2
Ergebnis	zur Begleitung von Externen	zum Verschließen von Fenstern und Türen

Attribut	20.04.26	29.05.26
Hinweis	[- Dies dient -] in [- erster Linie dazu -], unbefugte oder [- unbeaufsichtigte Zugriffe auf sensible Bereiche -], [- Informationen oder Systeme zu verhindern -]. [- Ohne eine solche Begleitung kann es leicht zu Situationen kommen -], in denen [- Externe absichtlich -] oder [- versehentlich sicherheitskritische Bereiche betreten -], [- vertrauliche Informationen einsehen -] oder [- technische Geräte unsachgemäß manipulieren -]. [- Die Begleitung Externer -], [- die wie Interne sicherheitsüberprüft und geschult wurden -], [- ist entbehrlich -].	[+ Durch unverschlossene Türen und Fenster könnten Unbefugte Zutritt erlangen und (+] in [+ Außenwänden +)] [+ auch Umwelteinflüsse wirksam werden (Regen , Sturm , Frost) , so dass IT , sensible Informationen und andere Werte in Gefahr geraten , zerstört , beschädigt , ausgespäht oder entfernt werden könnten . Sobald die Anwesenheit von Pesonen in einem Raum endet , sind Türen und Fenster daher so zu schließen , dass von Außen das +] unbefugte [+ Öffnen und (in Außenwänden) das Eindringen von Umwelteinflüssen verhindert wird . Türen werden z . B . abgeschlossen +] oder [+ Türschließsysteme in den entsprechenden Betriebszustand gebracht +], [+ Fenster ganz geschlossen und verriegelt +]. [+ Nicht erforderlich ist das Verschließen der Türen von fensterlosen Innenräumen +], in denen [+ keine IT , sensible Informationen +] oder [+ andere Werte aufbewahrt werden +], oder [+ wenn Risiken praktisch ausgeschlossen werden können +] ([+ z +]. [+ B +]. [+ Kippen von Außenfenstern in höheren Geschossen bei gutem Wetter vor kurzer Abwesenheit +]) [+ . Dies gilt auch für Gemeinschaftsräume , in denen sich IT - Systeme oder Datenträger befinden , z . B . VK - Konferenzzimmer . +]
Modalverb	KANN	SOLLTE
Präzisierung		beim Verlassen von Räumlichkeiten
Sicherheitsniveau	erhöht	normal-SdT
Tags	Physical Access Control, Advanced Persistent Threats (APT)	Physical Access Control
Text	Sensibilisierung für Mitarbeitende von Standorten KANN zur Begleitung von Externen anweisen.	Sensibilisierung für Nutzende von Gebäuden SOLLTE zum Verschließen von Fenstern und Türen beim Verlassen von Räumlichkeiten anweisen.
Titel	Begleitung Externer	Schließen von Türen und Fenstern
UUID	1f0a8e0c-33cd-407a-9579-e2dcc6d46515	2a761948-b26a-4e19-8a9d-75f78ac19811

Attribut	20.04.26	29.05.26
Verbesserung	SENS.8.4.1	
Zielobjekte	Mitarbeitende, Standorte	Nutzende, Gebäude

SENS.8.5 Mitbringen von IT-Systemen (erhöht)

Attribut	20.04.26	29.05.26
Aufwand	2	5
Dokumentation	Schulungsplan	Arbeitsanweisung
Ergebnis	zur sicheren Verwahrung von IT-Systemen und Datenträgern	das Mitbringen unautorisierter IT-Systeme
Handlungswort	sensibilisieren	untersagen
Hinweis	[- Herumliegende vertrauliche Dokumente und Datenträger -] sind ein [- leichtes Ziel für Diebe und -] können [- versehentlich verloren gehen -]. [- Hiergegen hilft die Verwahrung in einem verschlossenen Schrank oder anderweitig entsprechend geschützt -]. Dies [- ist besonders wichtig -] in [- Räumlichkeiten , welche oft zusammen mit oder ausschließlich von externen Personen genutzt -] werden, [- z . B . Konferenz - oder Veranstaltungsräume . -]	[+ Fremde IT - Systeme +] sind ein [+ Risiko , weil sie an das interne Netz angeschlossen , zum Mithören von Gesprächen oder zur Standortverfolgung missbraucht werden +] können. [+ Relevant sind dabei sowohl Geräte der Mitarbeitenden , als auch von Externen +]. Dies [+ kann auch durch eine Hinterlegung von Geräten an der Pforte oder +] in [+ verschließbaren Fächern am Eingang umgesetzt +] werden.
Modalverb	SOLLTE	KANN
Sicherheitsniveau	normal-SdT	erhöht
Tags	Physical Access Control	Bring Your Own Device
Text	Sensibilisierung für Nutzende von Räumen SOLLTE zur sicheren Verwahrung von IT-Systemen und Datenträgern sensibilisieren.	Sensibilisierung für Nutzende KANN das Mitbringen unautorisierter IT-Systeme untersagen.
Titel	Verwahrung Intern	Mitbringen von IT-Systemen
UUID	a5504b88-679b-418b-ab9e-5741317f29ff	6988844b-ed26-4ad3-83f6-ba5cf223070b
Zielobjekte	Nutzende, Räume	Nutzende

SENS.8.6 Begleitung Externer (erhöht)

Attribut	20.04.26	29.05.26
Aufwand	2	4
Ergebnis	zur Rückgabe nicht mehr benötigter Assets	zur Begleitung von Externen
Hinweis	Dies [- gilt z -]. [- B -]. [- bei einem Wechsel der Aufgaben -] oder [- der Beendigung des Vertragsverhältnisses zwischen Nutzenden -] und [- der Institution -].	Dies [+ dient in erster Linie dazu +], [+ unbefugte oder unbeaufsichtigte Zugriffe auf sensible Bereiche +], [+ Informationen +] oder [+ Systeme zu verhindern . Ohne eine solche Begleitung kann es leicht zu Situationen kommen , in denen Externe absichtlich oder versehentlich sicherheitskritische Bereiche betreten , vertrauliche Informationen einsehen oder technische Geräte unsachgemäß manipulieren . Die Begleitung Externer , die wie Interne sicherheitsüberprüft +] und [+ geschult wurden +], [+ ist entbehrlich . +]
Modalverb	SOLLTE	KANN
Sicherheitsniveau	normal-SdT	erhöht
Tags		Physical Access Control, Advanced Persistent Threats (APT)
Text	Sensibilisierung für Nutzende SOLLTE zur Rückgabe nicht mehr benötigter Assets anweisen.	Sensibilisierung für Mitarbeitende von Standorten KANN zur Begleitung von Externen anweisen.
Titel	Rückgabe nicht mehr benötigter Assets	Begleitung Externer
UUID	857f189a-5ede-47d6-89d5-faff63d736d2	1f0a8e0c-33cd-407a-9579-e2dcc6d46515
Zielobjekte	Nutzende	Mitarbeitende, Standorte

SENS.8.7 Beaufsichtigung Externer (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	3	2
Dokumentation	Schulungsplan	Arbeitsanweisung
Ergebnis	zur korrekten Verwendung bereitgestellter Brandschutz-Hilfsmittel	zur Beaufsichtigung von Externen in sensiblen Bereichen
Handlungswort	sensibilisieren	anweisen

Attribut	20.04.26	29.05.26
Hinweis	[- Hierzu zählt -] z. B. [- die Einweisung in die korrekte Verwendung von Handfeuerlöschern -] , [- welche in Serverräumen oder Rechenzentren bereitgestellt -] werden.	[+ Erhalten Externe wie +] z. B. [+ IT +] - [+ Dienstleister Zugang zu Standorten , an denen sensible Informationen verarbeitet +] werden, [+ so stellt eine Beaufsichtigung sicher , dass Externe nur soweit Zugriff auf diese Informationen erhalten , wie für die Erledigung der Aufgabe erforderlich . +]
Tags		Physical Access Control
Text	Sensibilisierung für Mitarbeitende SOLLTE zur korrekten Verwendung bereitgestellter Brandschutz-Hilfsmittel sensibilisieren.	Sensibilisierung für Mitarbeitende von Standorten SOLLTE zur Beaufsichtigung von Externen in sensiblen Bereichen anweisen.
Titel	Verwendung von Brandschuttmitteln	Beaufsichtigung Externer
UUID	37823d46-59ad-487b-bba1-5917c017c625	2b9cec51-f841-4ba6-b50d-29c1c2f2c21d
Verwandte		#ASST.5.6
Zielobjekte	Mitarbeitende	Mitarbeitende, Standorte

SENS.8.8 Verwahrung Intern (normal-SdT)

Attribut	20.04.26	29.05.26
Aufwand	3	2
Ergebnis	zur korrekten Verwendung bereitgestellter Wasserschutz-Hilfsmittel	zur sicheren Verwahrung von IT-Systemen und Datenträgern
Hinweis	[- Ohne ausreichende Kenntnisse könnte -] ein [- Mitarbeitender im Ernstfall zögern -] oder [- Hilfsmittel falsch anwenden -] , [- wodurch wertvolle Geräte ungeschützt bleiben -] oder [- unnötige Verzögerungen bei der Eindämmung eintreten könnten . Eine rechtzeitige und richtige Anwendung kann dagegen die Ausbreitung -] von [- Wasserschäden begrenzen , Datenverluste vermeiden und den Wiederanlauf kritischer Arbeitsprozesse erheblich erleichtern . Im Kontext dieser Anforderung bedeutet „ Wasserschutz - Hilfsmittel “ einfache technische oder organisatorische Werkzeuge , die zur Eindämmung , Ableitung oder Beseitigung von Wasser im Notfall eingesetzt -] werden [- können	[+ Herumliegende vertrauliche Dokumente und Datenträger sind +] ein [+ leichtes Ziel für Diebe und können versehentlich verloren gehen . Hiergegen hilft die Verwahrung in einem verschlossenen Schrank +] oder [+ anderweitig entsprechend geschützt +] . [+ Dies ist besonders wichtig in Räumlichkeiten , welche oft zusammen mit +] oder [+ ausschließlich +] von [+ externen Personen genutzt

Attribut	20.04.26	29.05.26
	, etwa Sandsäcke , Absperrschotten , Wassermelder oder Tauchpumpen . Konkrete Maßnahmen können sein : (1) Mitarbeitende regelmäßig in kurzen Übungen mit der Handhabung der vorhandenen Hilfsmittel vertraut machen -], z. B. [- das Einsetzen von Absperrschotten an Türen -] oder [- den Betrieb einer Tauchpumpe an einem vorbereiteten Testbecken -], [- (2) an den Aufbewahrungsorten der Hilfsmittel laminierte Schritt - für - Schritt - Anleitungen anbringen , die im Ernstfall sofort verständlich sind , (3) visuelle Markierungen oder QR - Codes platzieren , die auf kurze Videosequenzen zur Anwendung verweisen . Auch kleine Tipps können die Wirksamkeit erhöhen , etwa dass Hilfsmittel geordnet nach Dringlichkeit bereitliegen können oder dass bei Tauchpumpen vorab Kabel und Steckdosen auf sichere Reichweite geprüft werden können . -]	+] werden, z. B. [+ Konferenz - +] oder [+ Veranstaltungsräume +].
Modalverb	KANN	SOLLTE
Sicherheitsniveau	erhöht	normal-SdT
Tags		Physical Access Control
Text	Sensibilisierung für Mitarbeitende KANN zur korrekten Verwendung bereitgestellter Wasserschutz-Hilfsmittel sensibilisieren.	Sensibilisierung für Nutzende von Räumen SOLLTE zur sicheren Verwahrung von IT-Systemen und Datenträgern sensibilisieren.
Titel	Verwendung von Wasserschutzmitteln	Verwahrung Intern
UUID	75859261-aa48-4faf-9489-3d875e585f9d	a5504b88-679b-418b-ab9e-5741317f29ff
Zielobjekte	Mitarbeitende	Nutzende, Räume

TEST.4.1 Autorisierung von Änderungen (normal-SdT)

Attribut	20.04.26	29.05.26
Verbesserung	TEST.4.1.1, TEST.4.1.1.1, TEST.4.1.2	TEST.4.1.1, TEST.4.1.2, TEST.4.1.3

TEST.4.1.1 Unabhängigkeit der Autorisierung (erhöht)

Attribut	20.04.26	29.05.26
Verbesserung	TEST.4.1.1.1	

TEST.4.1.2 Staging (normal-SdT)

Attribut	20.04.26	29.05.26
Ergebnis	die Freigabe	die freizugebenden Änderungen
Handlungswort	dokumentieren	testen
Hinweis	[- Je nach Organisationstruktur kann es sinnvoll sein -], [- weitere Angaben aufzuführen -], z. B. in [- der Freigabe durchgeführte Prüfschritte oder weitere beteiligte Personen -]. [- Allerdings kann sich die Freigabe auch auf eine Dokumentation der zuvor durchgeführten Tests stützen . In jedem Fall handelt es sich nur dann um eine Freigabe , wenn die entscheidenden Personen oder Rollen eine eigenständige Entscheidung getroffen haben , die auf einer eigenen Untersuchung des Änderungsvorhabens basiert . -]	[+ Eine Staging +]- [+ Umgebung ist von der Produktivumgebung getrennt , wenn sie keine IT - Systeme , Anwendungen oder Datenquellen der Produktivumgebung verwendet . Sie entspricht so weit wie möglich der Produktivumgebung , damit zwischen Freigabe und Produktivbetrieb möglichst wenige Abweichungen vorkommen +], z. B. [+ hinsichtlich der Schwachstellen eingesetzter Softwareversionen oder der Verfügbarkeit von Ressourcen +] in [+ verschiedenen Rechenzentren +].
Präzisierung	einschließlich Zeitpunkt, Vorhaben, Freigabekriterien und freigebender Personen	in einer von der Produktivumgebung getrennten Staging-Umgebung, deren Komponenten so weit wie möglich der Produktivumgebung entsprechen,
Text	Änderungen und Tests SOLLTE die Freigabe einschließlich Zeitpunkt, Vorhaben, Freigabekriterien und freigebender Personen dokumentieren.	Änderungen und Tests SOLLTE die freizugebenden Änderungen in einer von der Produktivumgebung getrennten Staging-Umgebung, deren Komponenten so weit wie möglich der Produktivumgebung entsprechen, testen.
Titel	Dokumentation der Freigabe	Staging
UUID	97bc7db7-ea9d-47ea-9402-163af7470f4b	27cb8300-6019-432f-a688-82544667aca0
Verwandte	#ASST.5.7	